

LAB 04 — SIEM LOG ANALYSIS: SPLUNK

BOTSv1 Attack Chain Discovery, Methodology Pivot & TTP Mapping
CySA+ Home Lab Portfolio | Alejandro W. Orellana | June 2026

1. Lab Overview

This lab demonstrates SIEM-based threat hunting and attack chain reconstruction using Splunk and the Boss of the SOC v1 (BOTSv1) dataset — a pre-built collection of security logs from a simulated enterprise environment (Wayne Corporation / WAYNECORPINC). The objective was to perform log analysis, build detection queries, and identify adversary activity embedded in the data.

The original scope targeted EventCode 4625 (failed logon) for brute-force attack detection. Field validation confirmed this event code was not present in the BOTSv1 dataset. The lab was pivoted to EventCode 4688 (process creation) hunting — which produced a fully reconstructed, multi-stage attack chain involving Joomla CMS exploitation, web shell access, payload execution, file masquerading, lateral movement, and anti-forensics cleanup. Documenting and adapting when initial hypotheses do not match available data is a core analyst competency.

Field	Detail
Tool	Splunk Enterprise 9.3.2 (Free tier)
Dataset	BOTSv1 — Boss of the SOC v1 (Splunk, github.com/splunk/botsv1)
Dataset Period	August 2016 — historical static dataset, 3.6M+ events
Environment	Windows host — Splunk running on localhost:8000
Primary EventCode	4688 (Process Creation) — pivoted from original 4625 (Failed Logon)
ATT&CK Techniques	T1190, T1059.003, T1082, T1036, T1059.005, T1070.004, T1078
Accounts of Interest	joomla (service account), bob.smith (domain user / WAYNECORPINC)

2. Methodology Pivot — Why EventCode 4625 Was Abandoned

Prior to executing any detection queries, field validation was run to confirm which Windows Security EventCodes were actually present in the dataset:

```
index=botsv1 sourcetype=WinEventLog:Security | top EventCode
```

Results confirmed that EventCode 4625 (failed logon) did not appear in the dataset. The available EventCodes were 4688 (process creation), 4703 (token right adjusted), 4624 (successful logon), 4634 (logoff), 4674 (privileged object operation), and 4689 (process termination) — with 4688 accounting for the majority of events.

This outcome reflects a real-world analyst scenario: the BOTSv1 dataset's attack narrative centers on a web application exploitation chain rather than credential brute-forcing. Running field validation before committing to a detection strategy prevented several hours of dead-end query building. The pivot to EventCode 4688 process-creation hunting was the correct response — and ultimately surfaced the real attack embedded in the

data.

EventCode	Description	Count (approx)	Used In Investigation
4688	Process Creation	Majority of events	YES — primary detection surface
4703	Token Right Adjusted	8 events	Reviewed
4624	Successful Logon	Present	Reference
4634	Logoff	Present	Reference
4625	Failed Logon	NOT PRESENT	Original scope — abandoned after validation
4689	Process Termination	Present	Reference

3. Investigation Phase 1 — Process Creation Baselining

With EventCode 4688 confirmed as the primary data surface, investigation began with baselining all process creation activity across the dataset to identify anomalous executables:

```
index=botsv1 EventCode=4688 NOT New_Process_Name="*SplunkUniversalForwarder*" | stats count by Account_Name, New_Process_Name | sort -count
```

Analyst Note: The Splunk Universal Forwarder agent generates substantial process creation noise — binaries such as splunk-powershell.exe, splunk-admon.exe, and splunk-winprintmon.exe all match a naive *powershell.exe* wildcard. Excluding the SplunkUniversalForwarder path was required to surface meaningful user/service account activity. This is a common false-positive source in environments running Splunk forwarders.

Initial review of process names identified two accounts of interest: the **joomla** service account (running PHP web application processes) and **bob.smith** (a domain user account on the WAYNECORPINC domain). Both accounts showed process creation activity inconsistent with normal operations.

4. Investigation Phase 2 — Joomla Account Activity Analysis

The joomla service account was isolated and its activity bucketed into 5-minute windows to identify anomalous spikes:

```
index=botsv1 Account_Name="joomla" | bucket _time span=5m | stats count by _time | sort _time
```

Activity from 2016-07-31 through early 2016-08-10 was low and sporadic — consistent with normal Joomla CMS background operation (PHP-CGI handling legitimate web requests). A dramatic spike was identified on 2016-08-10 beginning around 14:25:

Time Window	Event Count	Assessment
07/31 – 08/09 (daily)	1–4 events / window	Normal baseline — CMS background activity
08/10 14:25	1	Attacker begins probing
08/10 14:40	10	Exploit attempts increasing
08/10 14:45	22 (PEAK)	RCE exploit landing — exploitation confirmed
08/10 14:55	6	Post-exploitation shell activity begins

08/10 15:00	20	Continued attacker activity via web shell
-------------	----	---

The exploitation window was then narrowed to examine the exact process sequence:

```
index=botsv1 Account_Name="joomla" earliest="08/10/2016:13:50:00"
latest="08/10/2016:15:00:00" | table _time, New_Process_Name, Process_Command_Line | sort
_time
```

5. Attack Chain Reconstruction

The following attack chain was fully reconstructed from process creation logs across the joomla and bob.smith accounts. All timestamps, commands, and process names are drawn directly from Splunk query output:

Timestamp	Account	Process	Command / Significance
08/10 14:40–14:46	joomla	php-cgi.exe	Repeated exploitation burst — 10–22 process creations per 5-min window. Consistent with CVE-2015-8562.
08/10 14:55:22	joomla	cmd.exe	cmd.exe /c "echo 24365" — Web shell execution confirmed. Echoing a random number is consistent with CVE-2015-8562.
08/10 14:55:24	joomla	cmd.exe	cmd.exe /c "dir 2>&1" — Windows directory listing.
08/10 14:55:26	joomla	cmd.exe	cmd.exe /c "ls 2>&1" — Linux-style listing. Mixed Windows/Linux commands confirm attacker familiarity.
08/10 14:55:33	joomla	cmd.exe	cmd.exe /c "ifconfig 2>&1" — Network interface recon.
08/10 14:56:18	joomla	cmd.exe	cmd.exe /c "3791.exe 2>&1" — First payload executed. Randomly named binary dropped to evade file-based detection.
08/10 14:58–15:05	joomla	(silent)	7-minute gap. 3791.exe running — likely establishing persistence, C2 connection, or staging additional payloads.
08/10 15:05:42	joomla	cmd.exe	cmd.exe /c "echo 63059" — Second shell ping with a different number. Indicates a new, successful session.
08/10 15:13–15:19	joomla	cmd.exe	Repeated dir commands — filesystem navigation.
08/10 15:20:10	joomla	cmd.exe	cmd.exe /c "move ..\1.jpeg 2.jpeg 2>&1" — File staging, renaming payload.
08/10 15:20:33	joomla	cmd.exe	cmd.exe /c "move 2.jpeg imnotbatman.jpg 2>&1" — Payload renamed to .jpg to evade file-based detection.
08/10 15:21:31	joomla	cmd.exe	cmd.exe /c "exit 2>&1" (x2) — Attacker cleanly exits shell.
08/24 09:43:21	bob.smith	cmd.exe	cmd.exe /V /C [heavily obfuscated VBScript] — Multi-hundred character randomly-cased command.
08/24 09:48:21	bob.smith	cmd.exe	Payload 121214.tmp executed from C:\Users\bob.smith\WAYNECORPINC\AppData\Roaming\Microsoft\Windows\CurrentVersion\Templates\
08/24 09:48:41	bob.smith	cmd.exe	taskkill /f /im "121214.tmp" + del — Process killed and file deleted immediately after execution.

6. MITRE ATT&CK Mapping

Technique ID	Name	Tactic	Observed Evidence
T1190	Exploit Public-Facing Application	Initial Access	Joomla php-cgi.exe exploitation burst consistent with CVE-2015-8562. 22 process creations in 6 minutes.
T1059.003	Command & Scripting Interpreter: Windows Command Shell	Execution	Attacker spawned cmd.exe via web shell under joomla account. Commands included dir, ls, ifconfig, echo, and file staging.
T1082	System Information Discovery	Discovery	dir, ls, ifconfig, echo commands run immediately after shell confirmation — reconnaissance phase.
T1036	Masquerading	Defense Evasion	Payload 3791.exe staged and renamed to imnotbatman.jpg. Disguising an executable as an image file.
T1059.005	Command & Scripting Interpreter: VBScript	Execution	Heavily obfuscated VBScript dropper executed under bob.smith on 08/24. Multiple random characters used for evasion.
T1070.004	Indicator Removal: File Deletion	Defense Evasion	taskkill + immediate del of 121214.tmp after execution. Self-cleanup to remove forensic artifacts.

T1078	Valid Accounts	Persistence / Lateral Movement	Attacker operated under the legitimate joomla service account throughout the
-------	----------------	--------------------------------	--

7. Analyst Findings

The initial access vector was likely CVE-2015-8562 (Joomla RCE). The observed pattern of repeated php-cgi.exe invocations under the joomla service account, spiking from a baseline of 1-4 events per window to 22 events in a single 5-minute period, is consistent with an automated exploit tool probing Joomla's PHP-CGI component. CVE-2015-8562 is a well-documented remote code execution vulnerability in Joomla versions prior to 3.4.6 that allows unauthenticated attackers to execute arbitrary PHP code.

The 7-minute silent gap between 14:58 and 15:05 is forensically significant. No process creation events were logged during this window despite the attacker maintaining access. This period likely represents 3791.exe running and performing activity not captured by EventCode 4688 — such as establishing a C2 connection, writing files to disk, or performing network-based lateral movement operations. This gap is a detection blind spot that would require network logs or endpoint telemetry to close.

The two distinct echo pings confirm two separate shell sessions. The first shell (echo 24365 at 14:55:22) and second shell (echo 63059 at 15:05:42) use different numbers — a standard attacker behavior to confirm a fresh connection vs. an existing session. The second session opening immediately after the silent gap suggests 3791.exe may have disrupted the original connection or established a new access mechanism.

The lateral movement to bob.smith occurred 14 days after initial access. The joomla account activity peaked on 08/10 while the bob.smith VBScript dropper ran on 08/24. This gap suggests the attacker maintained persistent access (potentially via imnotbatman.jpg or another mechanism established during the 14:58-15:05 silent window) before pivoting to a domain user account with different permissions.

Anti-forensics behavior confirms attacker awareness of detection. The immediate taskkill + file deletion sequence under bob.smith (payload executed then deleted within seconds) indicates the attacker anticipated forensic analysis. Self-cleanup is a tradecraft indicator that elevates the likely sophistication level of this threat actor.

8. Recommended Defensive Controls

Control	Implementation Guidance
Patch Management	Joomla 3.4.6+ patches CVE-2015-8562. Web-facing CMS platforms require aggressive patch cycles — days, not weeks.
Web Application Firewall	WAF rule blocking php-cgi.exe invocations with unusual User-Agent strings or HTTP method abuse would have caught the initial access.
Service Account Hardening	The joomla service account should not have permission to spawn cmd.exe or any shell interpreter. AppLocker or similar controls could have restricted this.
Process Creation Alerting	A Splunk alert on: index=botsv1 Account_Name=joomla New_Process_Name=*cmd.exe* would have fired at 14:55:22.
File Extension Monitoring	Alert on .exe files renamed to image extensions (.jpg, .png, .gif). This catches T1036 masquerading at the moment of execution.
Script Block Logging	Enable PowerShell Script Block Logging and Windows Script Host logging to capture obfuscated VBScript content.
EDR / File Deletion Monitoring	Endpoint detection tools that flag immediate file deletion post-execution (T1070.004) would have caught the bob.smith cleanup.
Network Segmentation	The web server running Joomla should not have had the network access needed to reach bob.smith's workstation.

